ALOUANI Fadi

BTS SIO 1
SLAM
03/11/26

TP :Hacking sans installation

Sommaire

Introduction....1
Hacking sans installation - Bases....2
Hacking sans installation - Divulgation de fichiers sensibles....4
Exercie portswigger : Source code disclosure via backup files....6
Exercie portswigger : Information disclosure on debug page....7
Hacking sans installation - Injection HTML and XSS....8
Hacking sans installation - Injection SQL....10
Conclusion....10

Introduction

Dans ce TP, je vais découvrir les bases du hacking éthique sans avoir besoin d'installer de logiciels ou d'outils particuliers. Je vais apprendre à comprendre le fonctionnement du Web, à analyser les URL et à découvrir les premières notions de vulnérabilités web.

ALOUANI Fadi

Hacking sans installation - Bases

Exercice 1 : Décomposition structurale d'une URL complexe

1) Décomposition de l'URL

URL étudiée : https://www.example.co.uk:4443/blog/article/search?color=blue&sort=newest

Après avoir analysé cette URL, j'ai identifié les différents éléments qui la composent :

- **Schéma (protocole) :** https, qui indique que la communication entre le navigateur et le serveur est sécurisée grâce au protocole HTTPS.
- **Sous-domaine :** www, qui correspond au sous-domaine du site.
- **Domaine principal :** example, qui représente le nom principal du domaine.
- **Domaine de premier niveau (TLD) :** .uk. L'ensemble .co.uk correspond à une extension structurée utilisée pour les domaines britanniques.
- **Numéro de port :** 4443, qui indique le port utilisé pour communiquer avec le serveur.
- **Chemin (path) :** /blog/article/search, qui indique la ressource ou la page demandée sur le serveur.

2) Caractère séparateur de la Query String

Le caractère qui permet de séparer le chemin de la Query String est le point d'interrogation ?.

Il indique le début des paramètres transmis au serveur dans l'URL.

3) Analyse de la Query String

La Query String de cette URL est : ?color=blue&sort=newest.

J'ai identifié deux paramètres :

- color=blue : la clé est color et sa valeur est blue. Elle permet de demander des produits de couleur bleue.
- sort=newest : la clé est sort et sa valeur est newest. Elle permet de demander un classement des résultats du plus récent au plus ancien.

Le symbole & permet de séparer les différents paramètres de la Query String.

Exercice 2 : Manipulation d'URL en direct sur YouTube

1) Observation des URL

En ouvrant deux vidéos différentes sur YouTube, j'ai constaté que la structure des URL reste globalement identique.

Par exemple :

Première vidéo : https://www.youtube.com/watch?v=abc123

Deuxième vidéo : https://www.youtube.com/watch?v=xyz456

J'ai remarqué que le paramètre v est présent dans les deux URL, mais que sa valeur change en fonction de la vidéo sélectionnée.

2) Modification manuelle du paramètre

J'ai ensuite remplacé la valeur du paramètre v dans la première URL par celle de la deuxième vidéo.

L'adresse est alors passée de :

https://www.youtube.com/watch?v=abc123

à :

https://www.youtube.com/watch?v=xyz456

Après avoir validé la nouvelle adresse, le navigateur a chargé la deuxième vidéo.

3) Conclusion

Cette manipulation m'a permis de constater que le paramètre v sert à identifier une vidéo précise sur YouTube.

En modifiant manuellement sa valeur dans la barre d'adresse, j'ai pu demander au serveur d'afficher une autre vidéo sans avoir besoin de passer par la page d'accueil ou de refaire une recherche.

J'en conclus que les paramètres d'une URL peuvent directement influencer le contenu demandé au serveur. Une simple modification de valeur peut donc permettre d'accéder à une ressource différente.

Exercice 3 : Modification de Query String et sensibilisation aux failles web

1) Rôle des variables color et sort

La Query String étudiée est : ?color=blue&sort=newest.

Après analyse, j'ai identifié deux variables :

- color=blue : ce paramètre permet de filtrer les produits selon leur couleur. Ici, seuls les produits bleus sont demandés.
- sort=newest : ce paramètre permet de trier les produits du plus récent au plus ancien.

Ces deux paramètres permettent donc de modifier les résultats affichés en fonction des critères de recherche de l'utilisateur.

2) Modification de la couleur des articles

Pour demander au serveur d'afficher les articles rouges au lieu des articles bleus, j'ai simplement remplacé la valeur blue par red.

La nouvelle Query String est :

?color=red&sort=newest

Le paramètre de tri reste inchangé, tandis que le filtre de couleur est modifié.

3) Ajout d'un troisième paramètre

J'ai choisi d'ajouter un paramètre size afin de filtrer les produits selon leur taille.

La nouvelle Query String devient :

?color=red&sort=newest&size=M
Dans cette nouvelle requête :

- color=red permet de sélectionner les produits rouges.
- sort=newest permet de trier les produits du plus récent au plus ancien.

- size=M permet de sélectionner les produits de taille M.

Le symbole & permet de séparer les trois paramètres.

4) Question de réflexion : Cybersécurité et vulnérabilités IDOR

La modification manuelle des paramètres d'une URL constitue une première étape lors d'un audit de sécurité, car elle permet de vérifier si une application contrôle correctement les informations envoyées par l'utilisateur.

J'ai compris que certains paramètres peuvent contenir des identifiants permettant d'accéder à des ressources précises. Par exemple, une URL comme https://site.com/profile?id=100 peut permettre d'afficher le profil correspondant à l'identifiant 100.

Une vulnérabilité de type IDOR (Insecure Direct Object Reference) peut apparaître lorsqu'un utilisateur modifie cet identifiant et parvient à accéder aux informations d'un autre utilisateur sans autorisation.

Le problème vient généralement d'un contrôle d'accès insuffisant côté serveur. En effet, le serveur ne doit pas simplement vérifier si l'identifiant demandé existe, mais également si l'utilisateur connecté possède les droits nécessaires pour accéder à la ressource.

Pour éviter ce type de vulnérabilité, il est nécessaire de mettre en place des vérifications d'autorisation côté serveur pour chaque ressource demandée.

Conclusion :

Cette manipulation montre qu'il est important de ne jamais faire confiance aux paramètres transmis dans une URL. Lors d'un audit de sécurité autorisé, leur modification permet de vérifier si les contrôles d'accès sont correctement appliqués et de rechercher d'éventuelles vulnérabilités comme les IDOR.

Hacking sans installation - Divulgation de fichiers sensibles

Exercice : Analyse du fichier robots.txt

1) Accéder au site Wikipédia

Je me suis rendu sur Wikipédia et j'ai ajouté /robots.txt à la fin de l'adresse pour afficher son fichier

robots.txt :

https://www.wikipedia.org/robots.txt

2) Afficher le contenu du fichier robots.txt

J'ai constaté que ce fichier contient plusieurs instructions destinées aux robots d'indexation. Elles permettent de définir les parties du site qu'ils peuvent ou ne peuvent pas explorer.

3) Différence entre les deux instructions

- User-agent: DOC suivi de Disallow: / : interdit au robot DOC d'explorer l'ensemble du site.
- User-agent: IsraBot suivi de Disallow: : aucune restriction n'est définie pour ce robot, il peut donc explorer le site.

4) Afficher le fichier robots.txt de Semrush

Je me suis rendu sur l'adresse suivante :

https://www.semrush.com/robots.txt

J'ai pu consulter les différentes règles utilisées par Semrush pour gérer l'exploration de son site par les robots.

5) Le dossier /projects/ est-il autorisé à l'exploration ?

Oui, le dossier /projects/ est globalement autorisé à l'exploration.

L'instruction qui le montre est :

Allow: /projects/

6) Expliquer Disallow: /projects/?*

Cette instruction interdit aux robots d'explorer les URL du dossier /projects/ qui contiennent des paramètres dans leur Query String.

Par exemple : /projects/?id=123.

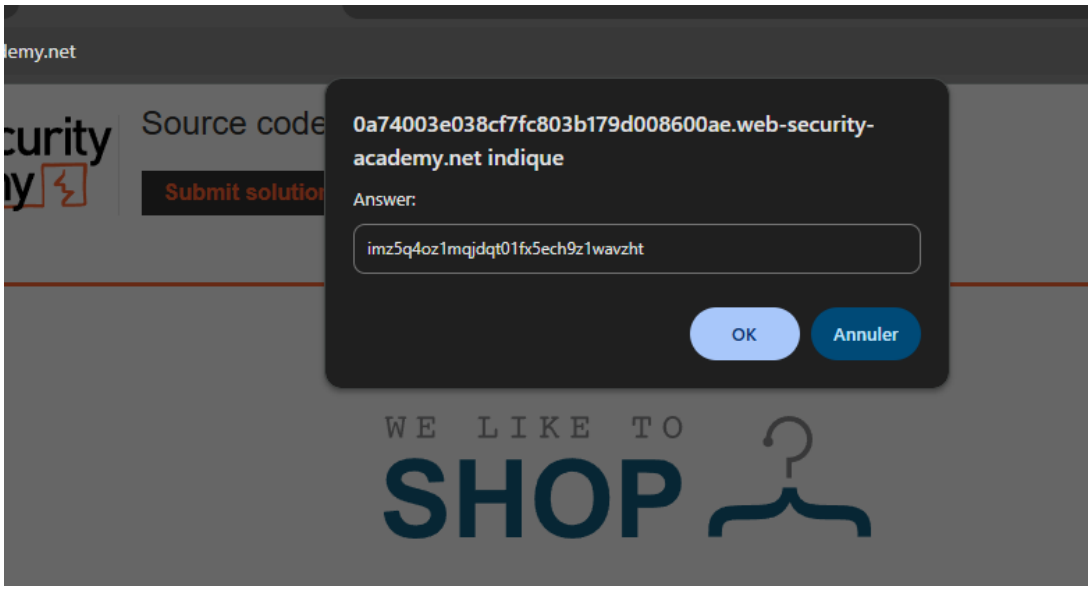
Le symbole ? indique le début des paramètres et * représente une suite de caractères.

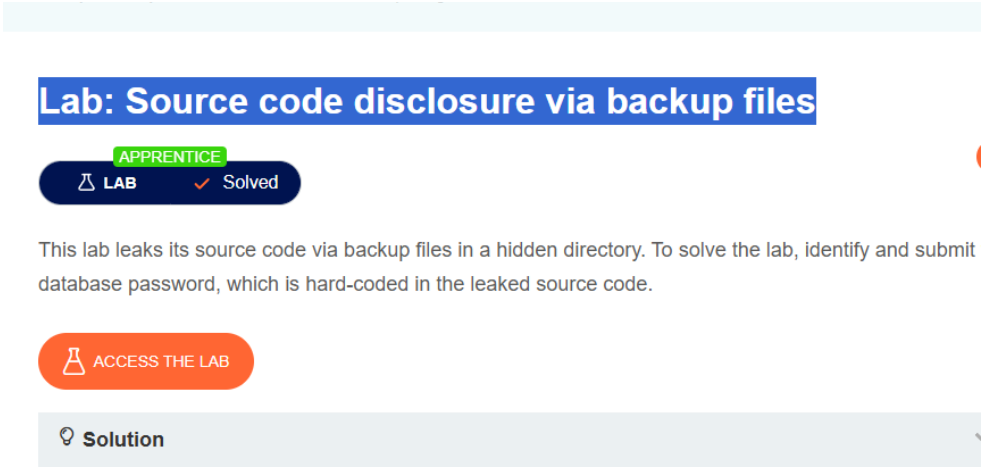
Conclusion :

J'ai compris que le fichier robots.txt permet de contrôler l'exploration d'un site par les robots d'indexation. Il permet notamment d'autoriser ou d'interdire l'exploration de certaines pages ou parties du site.

Exercie portswigger : Source code disclosure via backup files

J'ai commencé par consulter le fichier `robots.txt`, qui m'a indiqué l'existence d'un dossier `/backup`. Je m'y suis rendu et j'ai trouvé un fichier nommé `ProductTemplate.java.bak`. En l'ouvrant, j'ai découvert le code source de l'application ainsi que le mot de passe de la base de données. J'ai ensuite soumis ce mot de passe pour valider le lab.

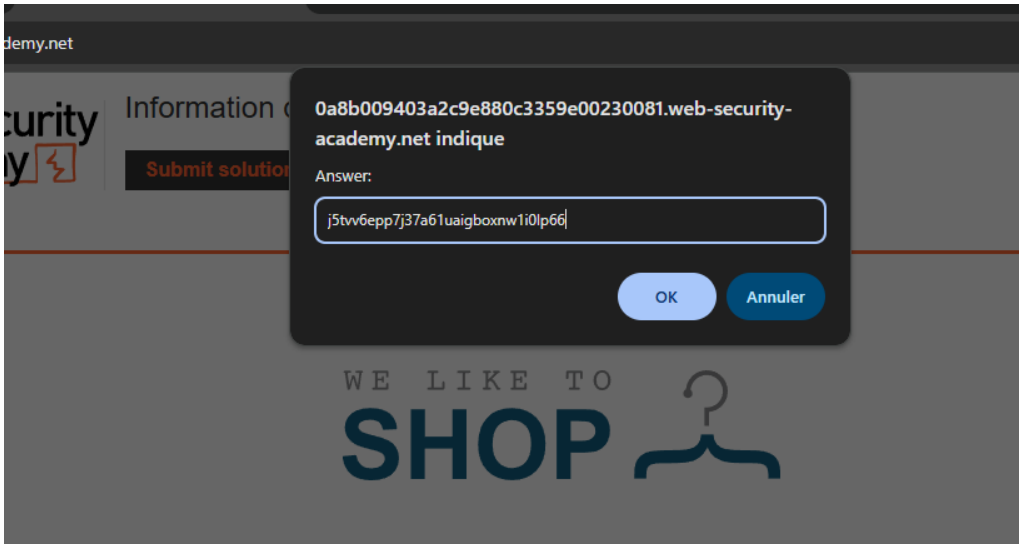


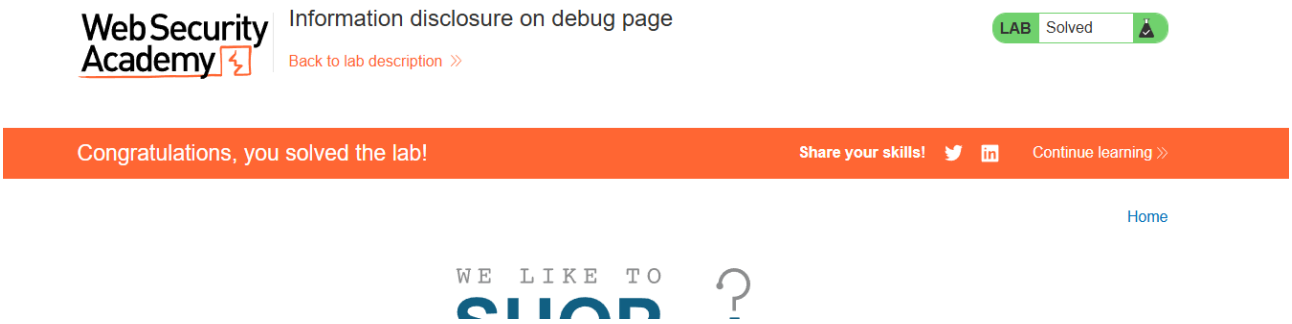


ALOUANI Fadi

Exercie portswigger : Information disclosure on debug page

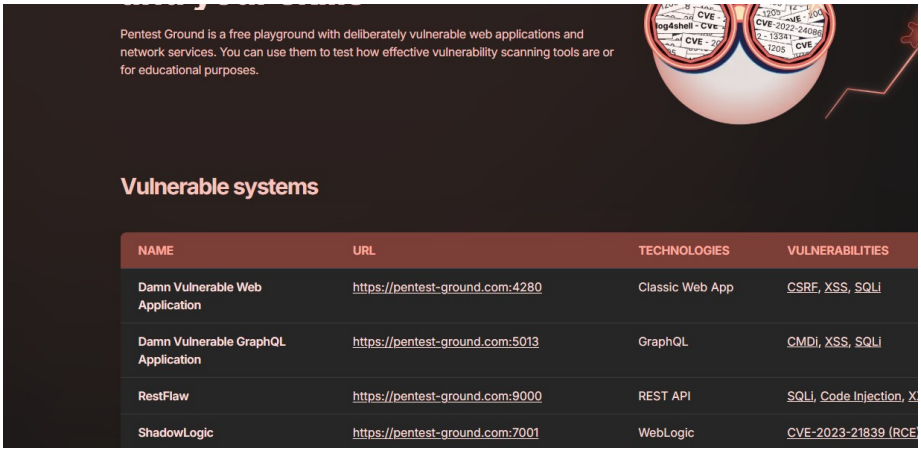
J'ai recherché une page de débogage sur le site et j'ai trouvé le fichier `phpinfo.php`. En l'ouvrant, j'ai pu consulter les informations de configuration du serveur PHP. J'ai recherché la variable SECRET_KEY, récupéré sa valeur et l'ai soumise pour résoudre le lab.

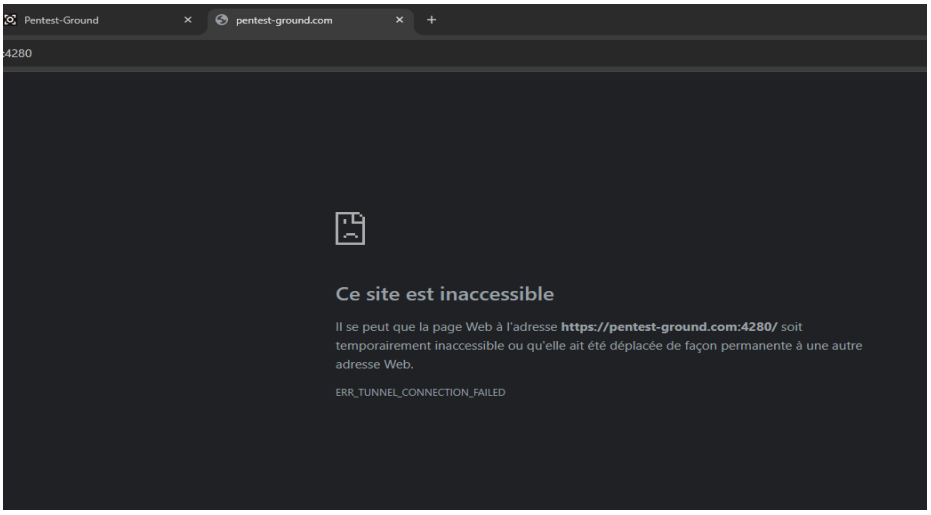




Hacking sans installation - Injection HTML and XSS

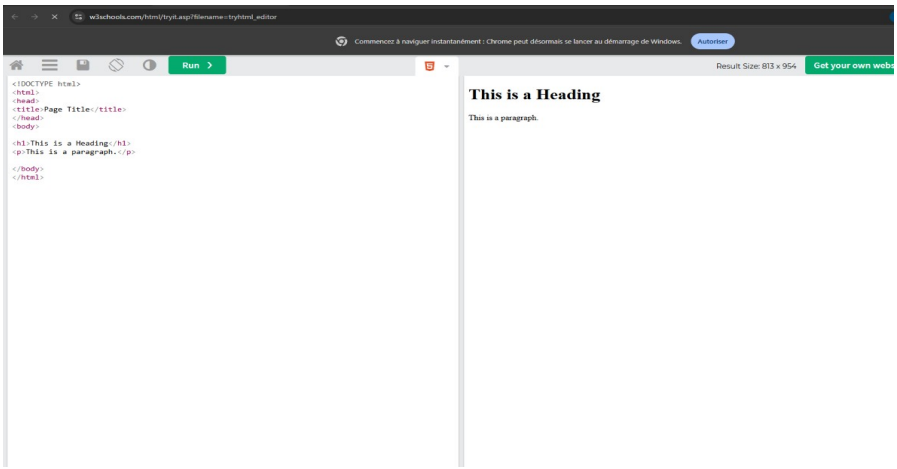
Comme indiqué dans le TP, j'ouvre le premier lien fourni, mais je pense que le proxy bloque la connexion à cette page.





ALOUANI Fadi

Manipulation du code HTML sur W3Schools



a) Saisie de mon nom sans balises HTML
Après avoir saisi mon nom dans l'éditeur et cliqué sur « Run », celui-ci apparaît dans la fenêtre de droite sous forme de texte normal.

**b) Saisie de mon nom avec les balises et **
En ajoutant les balises et autour de mon nom, celui-ci apparaît en gras dans la fenêtre de droite. Cela montre que le navigateur interprète les balises HTML.

Conclusion :
L'injection HTML fonctionne : il est possible de modifier

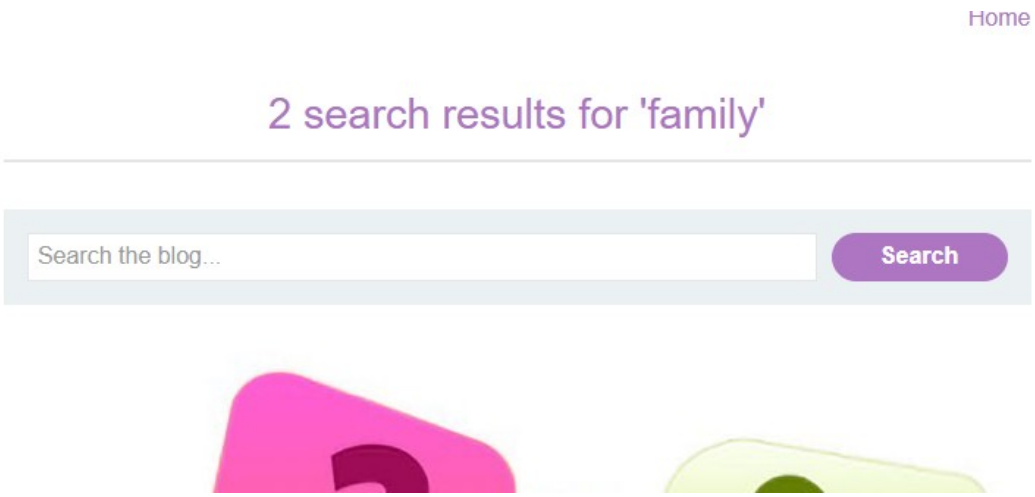
Labo2 :

1) Aller sur le site : https://portswigger.net/web-security/all-labs



3) Tests de recherches

a) Effectuer une recherche, par exemple avec le mot "**family**"



b) Effectuer une autre recherche avec le mot "**hacking**"
Dans ce cas-là, il n'y a aucun résultat

c) Essayons de faire une injection HTML en plaçant le mot "hacking" en gras :

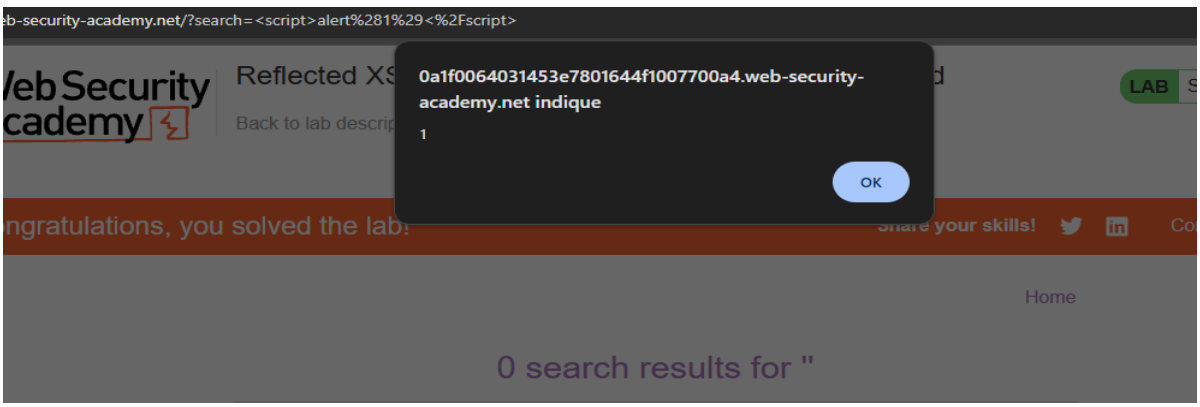
Que doit-on taper dans le moteur de recherche ?

hacking

Que doit-on taper pour avoir hacking en italique ?

hacking

d) Essayons de faire une injection XSS en utilisant la balise de test classique: **<script>alert(1)</script>**

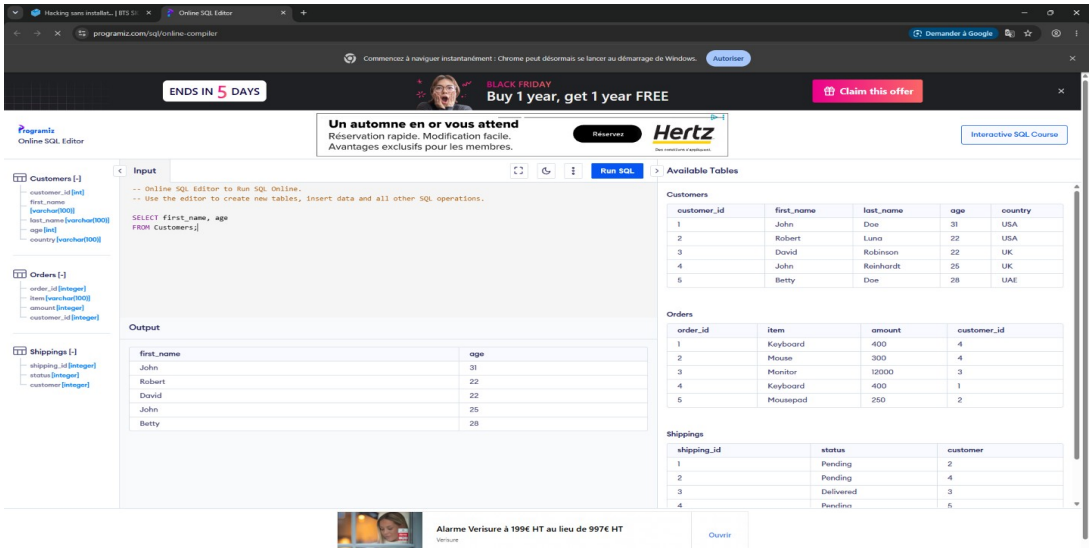


ALOUANI Fadi

Hacking sans installation - Injection SQL

Exercice :

1) Aller sur le compilateur SQL en ligne du site Programiz : https://www.programiz.com/sql/online-compiler



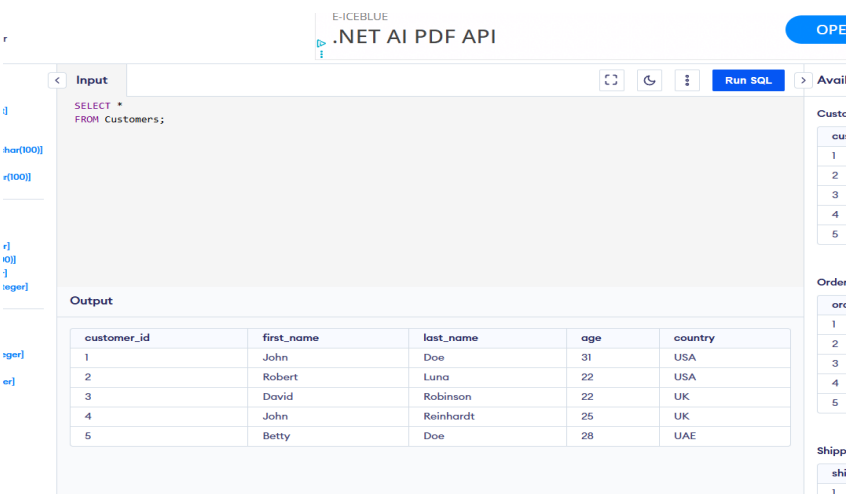
2) Combien voit-on de tables ?

Il y a 3 tables

3) Quelle requête SQL permet d'afficher tous les champs de la table Customers ?

```
SELECT *
FROM Customers;
```

4) Tester quelques requêtes et observer les résultats en cliquant sur le bouton **Run SQL** :



5) Quelle requête permet d'afficher les lignes de la table Customers pour lesquelles le prénom est "John" ?

```
SELECT *
FROM Customers
WHERE first_name = 'John';
```

6) Combien d'occurrences sont affichées ?

2 occurrences (il y a 2 clients qui s'appellent John).

7) Quelle requête permet d'afficher les lignes de la table Customers pour lesquelles le prénom est "John" et le nom est "Doe"?

```
SELECT *
FROM Customers
WHERE first_name = 'John'
AND last_name = 'Doe';
```

8) Combien d'occurrences sont affichées ?

1 occurrence (John Doe).

9) Que se passe-t'il si l'on ajoute 2 tirets avant and ? Pourquoi ?

Les deux tirets (`--`) transforment la suite de la ligne en commentaire. La condition après les tirets n'est donc pas exécutée par SQL.

10) Que se passe-t'il si l'on ne connaît pas le prénom ?

On peut utiliser une autre information pour rechercher la personne, par exemple son nom de famille, avec la commande `WHERE`.

11) Un pirate pourrait transposer cette requête en la requête suivante :

```
SELECT * FROM Customers WHERE username = "John" AND password = "xxxxx";
```

Quelle requête générer dans notre base ? _____
Obtient-on des lignes de résultats ?

La requête est :

```
SELECT * FROM Customers WHERE username = "John" -- AND password = "xxxxx";
```

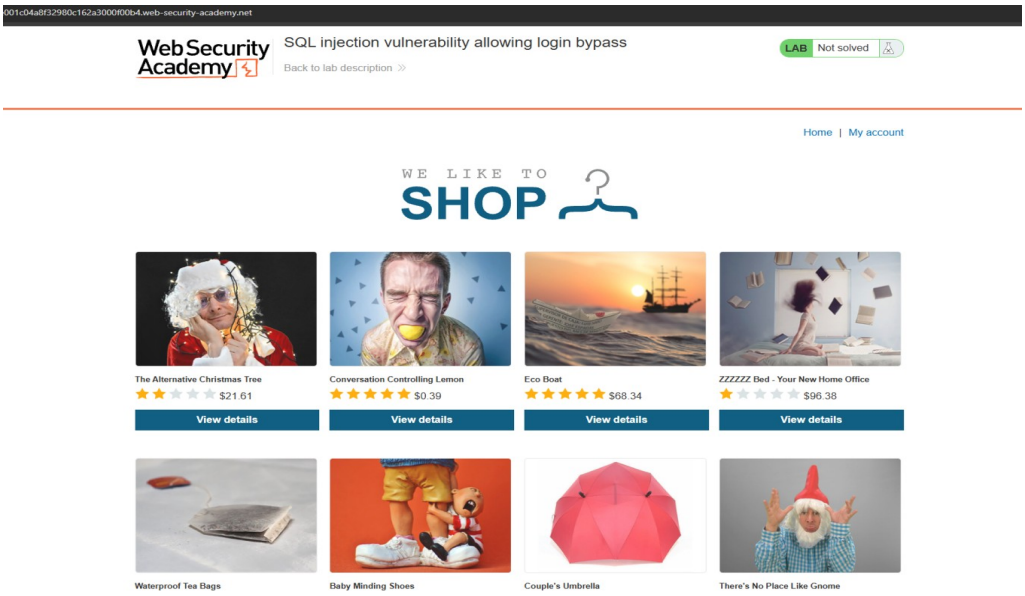
Oui, on obtient des lignes de résultats, car les deux tirets transforment la condition du mot de passe en commentaire.

12) La requête précédente ne fonctionnera pas car il faut absolument rentrer un mot de passe pour accèder à la suite.
Dans notre exemple, il est représenté par la valeur contenue dans last_name.
Donc le pirate peut arriver à faire croire que le mot de passe est vrai en rajoutant la chaine suivante :

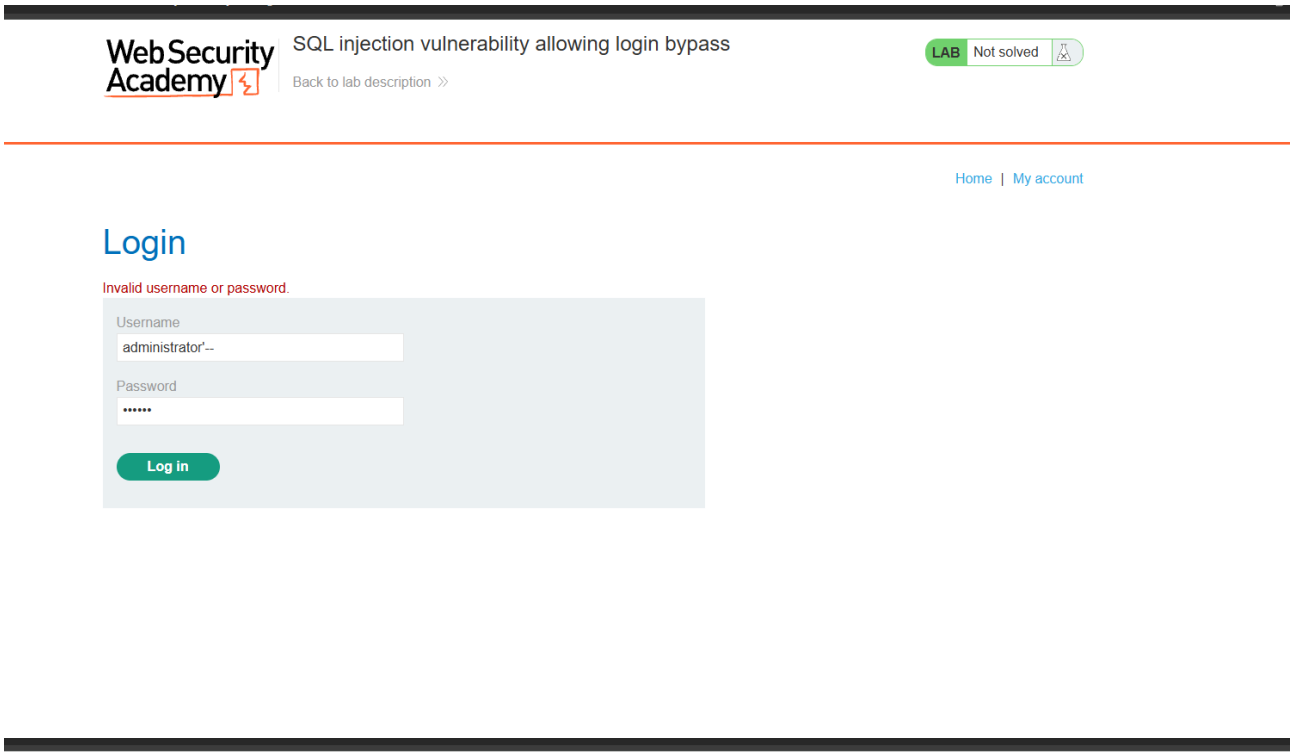
```
" or  1=1--
```

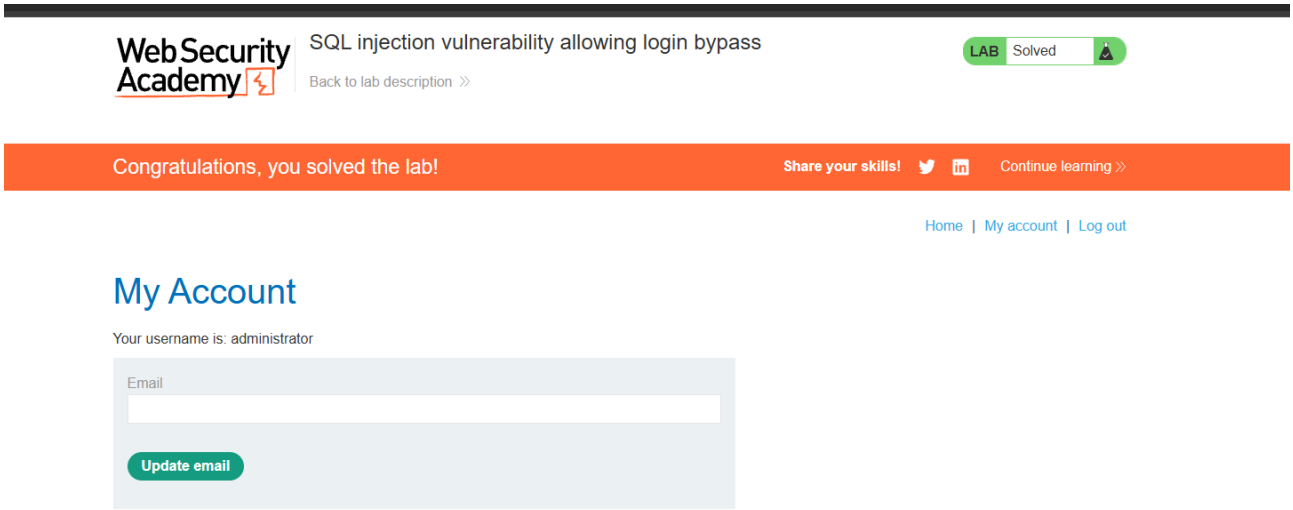
Oui, la requête fonctionne, car la condition `1=1` est toujours vraie.

Exercice portswigger : Labo de Contournement d'authentification par injection SQL



Terminer l'exercice...





Le mot de passe peut être quelconque, car l'injection SQL (`administrator'--`) permet de neutraliser la vérification du mot de passe et de se connecter directement au compte administrateur.

Conclusion

Ce TP m'a permis de découvrir les bases du hacking éthique et de mieux comprendre le fonctionnement du Web. J'ai appris à analyser et modifier des URL, ainsi qu'à comprendre les risques liés aux failles de sécurité comme les IDOR.